

Digital Signature: TSE-Signatur Verifikation

Anleitung zur Verifikation einer TSE-Unterschrift auf Kassenbons mit QR

Die Technische Sicherheitseinrichtung (TSE) ist ein vorgeschriebenes Sicherheitsmodul, das alle Kassenvorgänge lückenlos, unveränderbar und maschinell auswertbar speichert.

Bei jedem Kassenvorgang sendet die Kasse die relevanten Daten (z.B. ID, Betrag, Steuern, Vorgangsart) an die TSE, wo sie mit einer fortlaufenden Transaktionsnummer, einem Signaturzähler und einem Zeitstempel versehen werden. Die TSE-Signatur auf Kassenbons belegt kryptografisch, dass ein Bon zu einer unverändert gespeicherten Transaktion in der TSE gehört und dass die Kassenaufzeichnungen nicht nachträglich manipuliert wurden.

Die digitale Unterschrift kann prinzipiell verifiziert werden. Dazu sind folgende Schritte nötig:

Schritt 1: Erstellung der LOG-MESSAGE gemäß BSI TR-03151

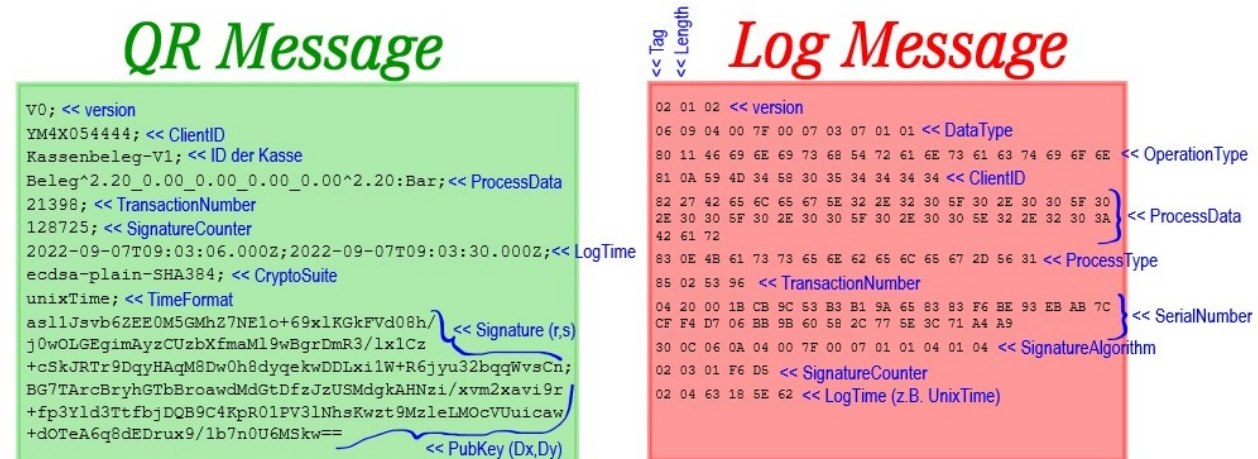
Der Aufbau der Log Message folgt der Beschreibungssprache ASN.1/DER. Jeder Eintrag wird mittels Tag-Length-Value-Format. Die Tags stammen aus folgender Spezifikation:

Datenfeld	Tag	Kurzbeschreibung	Werte	Pflicht
Log Message	0x30	Gesamte Message		Muss
version	0x02	Version vom Log Message Format	Fester Wert = 2	Muss
certifiedDataType	0x06	Art und Typ der Protokollnachricht	Fester Wert = 0.4.0.127.0.7.0.3.7.1.1	Muss
certifiedData				
1. operationType	0x80	Spezifizierung der Protokollmeldung	Fester Wert = FinishTransaction	Muss
2. clientID	0x81	ID der Applikation		Muss
3. processData	0x82	Daten aus dem Kassenbeleg		Muss
4. processType	0x83	Art des Vorganges	Kassenbeleg-V1, Bestellung etc.	Muss (Auswahl)
5. additionalExternalData	0x84	Zusätzliche Informationen		Optional
6. transactionNumber	0x85	Transaktionsnummer		Muss
7. additionalInternalData	0x86	Zusätzliche Informationen		Optional
serialNumber	0x04	Seriennummer der TSE		Muss
signatureAlgorithm	0x30	Informationen zur Signaturerstellung	Fester Wert für SHA384 = 0.4.0.127.0.7.1.1.4.1.4	Muss
algorithm	0x06	Verwendeter Signaturalgorithmus		Muss
parameters		Ergänzende Angaben zum Signaturalgorithmus		Optional
seDataAudit	0x04	Audit Protokoll-Daten		Optional
signatureCounter	0x02	Signaturzähler		Muss
logTime		Auswahl einer Zeitmethode		
- utcTime	0x17	Format: YYMMDDhhmmZ		Auswahl
- generalizedTime	0x18	Format: YYYYMMDDhhmmssZ		Auswahl
- unixTime	0x02	Format: YYYYMMDDhhmmssZ	Unix Timestamp als 64-Bit Integer Zahl dargestellt	Auswahl

Die Serial Number ist der SHA256-Hashwert des Public Key (Dx, Dy) (einschließlich des Tags 04).

Die Codierung der Signature-Algorithmen-Suite erfolgt über den Identifier Octet Descriptor (siehe <http://oid-info.com/get/0.4.0.127.0.7.1.1.4.1.4>).

Beispiel:



Schritt 2: Hashwert der LOG-MESSAGE berechnen

Die Log Message wird als Byte-String mittels des spezifizierten Hash-Verfahrens (z.B. SHA384) aus der QR-Message gehasht. Der zugehörige Hashwert h geht in die ECDSA-Signatur ein.

Im Beispiel:

```

M=020102060904007F000703070101801146696E6973685472616E73616374696F6E810A594D3458303
534343434822742656C65675E322E32305F302E30305F302E30305F302E30305F302E30305E322E3230
3A426172830E4B617373656E62656C65672D5631850253960420001BCB9C53B3B19A658383F6BE93EBA
B7CCFF4D706BB9B60582C775E3C71A4A9300C060A04007F00070101040104020301F6D5020463185E62
  
```

```

h:=SHA384(M)=4ABBE1B76CF8B8FC3288795E7E9A733C9A03840D8BBAF683ACB3EE63790C749C7052A2
3A91C285DEDAF2EE1AC24880E6
  
```

Schritt 3: Passende Elliptische Kurve ermitteln

Bei TSE-Unterschriften auf Kassenbons ist die elliptische Kurve nicht explizit spezifiziert. Die genaue Kurve ist im zugehörigen Zertifikat hinterlegt. In der Regel werden eine Brainpool-Kurve (z.B. brainpoolP256r1 OID: 1.3.36.3.3.2.8.1.1.7) oder eine SECG-Kurve (z.B. secp256r1, OID: 1.2.840.10045.3.1.7) verwendet.

Die Elliptische Kurve E wird üblicherweise durch die Parameter p , a , b , Gx , Gy und die Ordnung $n := \text{ord}_E(G)$ spezifiziert.

Man kann die verwendete Kurve E detektieren, indem man prüft, ob der Punkt D , dessen Koordinaten (Dx, Dy) im QR-Code stehen, auf der betrachteten Kurve E liegt, also $D \stackrel{?}{\in} E$.

Schritt 4: Digitale Signatur verifizieren

Die digitale Signatur (r, s) steht im QR-Code. Hiermit berechnet man den Punkt

$$L := [s^{-1}]([h]G + [r]D) \in E$$

und überprüft, ob die x -Koordinate des Punktes L exakt r ist (mod $\text{ord}_E(G)$).